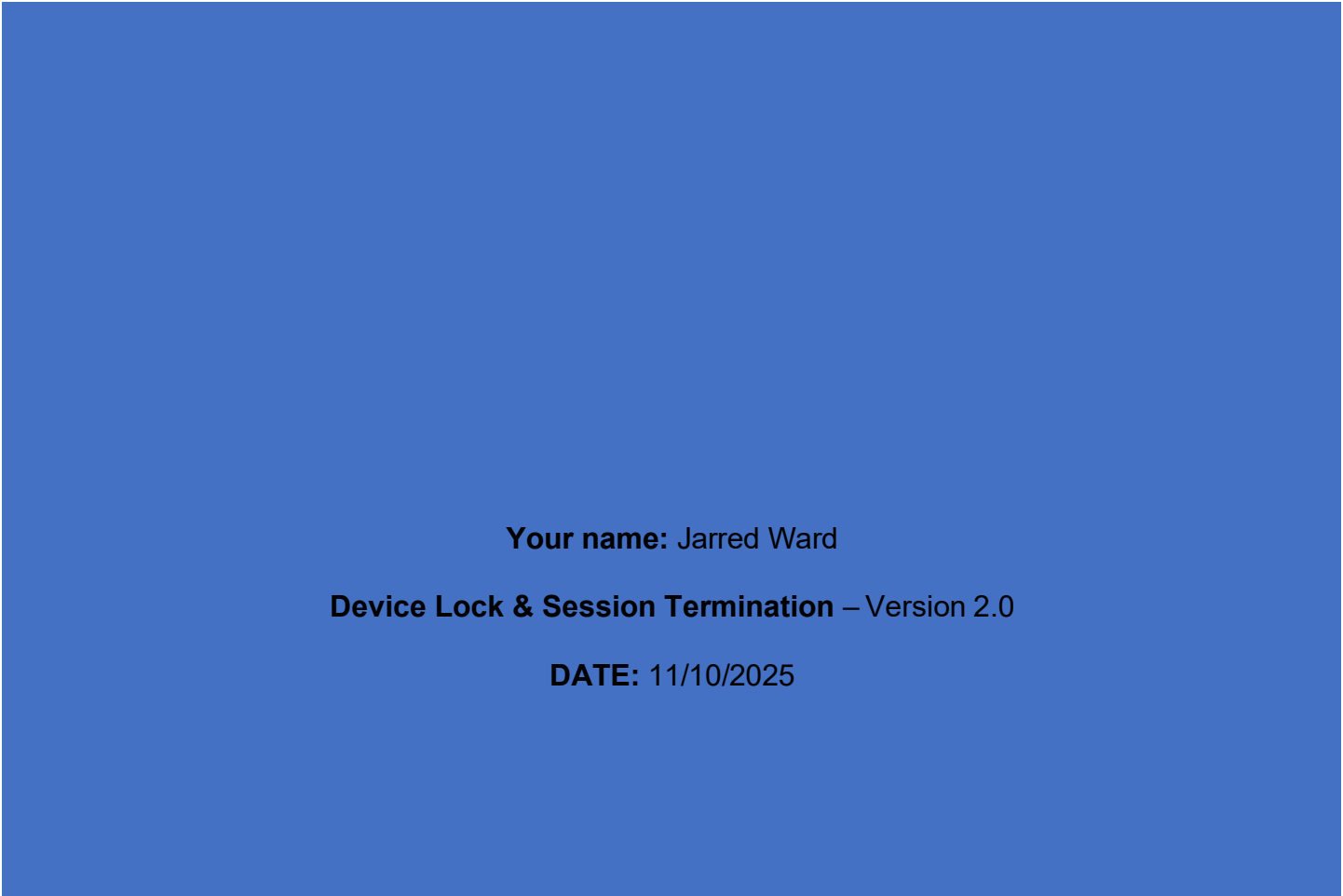




SNOWBE ONLINE

Policy# AC-11 & AC-12 Device Lock & Session Termination



Your name: Jarred Ward

Device Lock & Session Termination – Version 2.0

DATE: 11/10/2025

Table of Contents

PURPOSE..... 2

SCOPE..... 2

DEFINITIONS..... 2

ROLES & RESPONSIBILITIES 3

POLICY 4

EXCEPTIONS/EXEMPTIONS 4

ENFORCEMENT 5

VERSION HISTORY TABLE 5

CITATIONS 6

Purpose

SnowBe Online enforces automatic device locks and session terminations to protect customer, financial, and system data when devices or sessions are left unattended. This policy establishes timeouts, lock settings, and termination rules across desktops, laptops, retail terminals, and AWS administrative sessions. These measures prevent unauthorized viewing or access, supporting PCI DSS compliance and SnowBe's security framework.

Scope

This policy applies to all SnowBe-owned and managed devices, including desktops, laptops, POS terminals, mobile devices, and cloud administration sessions. It covers all user interactions with SnowBe information systems, whether in office locations, retail stores, or remote environments connected to AWS.

Definitions

Device Lock

Device lock is a security feature that automatically restricts access to a device until a user re-authenticates.

Idle Timeout

Idle timeout is the period of inactivity that triggers an automatic lock or termination of a session.

Session Termination

Session termination is the process by which an authenticated session ends automatically after a specified period of inactivity.

Shared Workstation

A shared workstation is a computer or terminal used by multiple employees during rotating shifts.

Timeout Profile

A timeout profile is a standardized configuration defining the lock and termination intervals for specific device categories or user roles.

Unattended Session

An unattended session is an active session that remains logged in but lacks user supervision or presence.

Roles & Responsibilities

Application Owner

Ensures that each application enforces appropriate timeout values and session-ending mechanisms. They also test and validate that users are automatically logged out or locked after inactivity as required by this policy.

Chief Information Security Officer (CISO)

The CISO oversees SnowBe Online's information security strategy, ensuring alignment with business goals, NIST 800-53 controls, and PCI DSS compliance. This role leads risk management, approves major security initiatives, and reports the company's security posture to executive leadership.

Endpoint Engineer

Configures operating system lock timers, pattern-hiding displays, and inactivity limits through SnowBe's mobile device management platform. The team continuously reviews these configurations to confirm they meet security standards and compliance expectations.

GRC Team

Defines timeout profiles based on data sensitivity and reviews compliance during scheduled audits. The GRC team updates timeout values when risk assessments or threat intelligence indicate a need for stronger protections.

IT Security Manager

The IT Security Manager implements and enforces security controls across SnowBe's AWS and on-premise systems. This role manages daily operations, coordinates vulnerability management, and ensures policy compliance through training and incident oversight.

Retail Operations

Ensures that point-of-sale and kiosk devices automatically lock after short idle periods and terminate sessions at the end of each shift. This department is also responsible for verifying that retail terminals remain secured when unattended.

Service Desk

Verifies that device lock settings are applied correctly during provisioning and deployment. The Service Desk also investigates user reports related to device lock or session timeout issues and resolves them promptly.

User

Manually locks their workstation whenever leaving it unattended and complies with all automatic lock or termination settings. Users are prohibited from disabling, extending, or bypassing enforced timeouts on any SnowBe device or session.

Policy

All SnowBe-managed devices and sessions shall automatically lock or terminate after a defined period of inactivity to prevent unauthorized access to sensitive information. Corporate laptops and desktops must lock after ten minutes of inactivity and require MFA re-authentication. Shared POS terminals and kiosk systems shall lock after three minutes of inactivity, and administrative consoles or jump hosts shall lock after five minutes. These settings apply to all SnowBe systems, including those hosted in AWS and within retail environments. Users are required to manually lock their devices before leaving them unattended, regardless of duration. Pattern-hiding displays must be enabled on all compatible devices to prevent shoulder surfing or visual data exposure in shared or public areas.

Web and application sessions that process customer, payment, or administrative data shall terminate automatically after inactivity thresholds are reached. Administrator sessions must end after fifteen minutes of inactivity, customer service sessions after twenty minutes, and VPN sessions upon extended inactivity or at the end of a user's shift. Sessions must also terminate upon device sleep, network change, or enforcement of updated security policy. Re-authentication after a lock or termination must occur using the same or stronger method, including MFA for privileged accounts. Acceptable behavior includes manually locking devices when stepping away, using MFA for all privileged re-authentications, and immediately logging out of applications after completing tasks. Unacceptable behavior includes disabling or extending timeout settings, leaving devices unlocked or unattended, sharing login sessions with other users, or using unauthorized tools to bypass lock screens. Attempts to modify or override session termination policies are considered violations of this policy and subject to disciplinary action.

- **AC-11 (1) Pattern-Hiding Displays** – Masks information on locked screens to protect sensitive order and payment data from unauthorized viewing.
- **AC-12 (1) User-Initiated Logouts** – Allows users to securely end sessions after completing tasks to prevent hijacking or lingering connections.
- **AC-12 (2) Termination Message** – Displays a notification confirming secure session termination.
- **AC-12 (3) Timeout Warning Message** – Warns users prior to automatic termination, allowing them to save work or maintain productivity securely.

Exceptions/Exemptions

Requests for exceptions must be submitted in writing to SnowBe Online's IT Security Manager for review and approval. Each request must include the business justification, defined scope, duration, and any compensating controls that will be applied. All approved exceptions will be formally documented, reviewed periodically for continued appropriateness, and remain valid for no longer than one year unless re-evaluated and re-approved.

Enforcement

Failure to follow this policy may result in disciplinary action, beginning with a verbal warning and escalating to written notice, suspension of system access, or termination of employment. Contractors and vendors who violate SnowBe Online’s security or compliance requirements may have their access revoked or contracts terminated. Intentional or severe violations, especially those involving customer data or payment systems, may lead to termination and potential legal or regulatory action under applicable laws.

Version History Table

Version #	Implementation Date	Document Owner	Approved By	Description
1.0	11/3/2025	Jarred Ward	IT Security Manager	Original Draft
2.0	11/10/2025	Jarred Ward	IT Security Manager	Updated Access Control Policy

Citations

Georgia Technology Authority - <https://gta-psg.georgia.gov/psg/network-access-and-session-controls-ss-08-048> (Used for Purpose, Scope, Definitions).

State of Illinois - <https://doit.illinois.gov/content/dam/soi/en/web/doit/documents/support/policies/2021/access%20control-policy.pdf> (Used for Enforcement, Exceptions/Exemptions).

State of Maine - <https://www.maine.gov/oit/sites/maine.gov/oit/files/inline-files/AccessControlPolicy.pdf> – (Used for Policy, Roles & Responsibilities).